



University of Piraeus

School of Information and Communication Technologies

Department of Digital Systems

Level: Master's Programme of Studies

Wireless and Mobile Network Security

Android-Use Case 1

Supervising Professors: Christos Xenakis and Georgios Efthymoglou
(Grigorios Papoutsis)

Ioannis Kalaitzidis

ioannis_kalaitzidis@ssl-unipi.gr

Piraeus

Abstract

Implementation of security testing (penetration testing) and reverse engineering on two vulnerable Android applications, with the goal of extracting sensitive data (flags) stored insecurely in the local storage of the device.

Abstract

Implementation of penetration testing and reverse engineering on two vulnerable Android applications with the objective of identifying hidden flags. The research involved analysis via the Apktool utility for inspecting critical configuration files, and via Android Studio for exploring the internal file system. Through this process, the critical vulnerability of insecure local storage was exposed, as credentials were found without any encryption (plain-text). Specifically, the flags were successfully recovered from the temporary SQLite memory logs (Write-Ahead Log) of the first application and from the Shared Preferences XML files of the second.

Contents

Introduction.....	
Practical part of the assignment.....	
Bibliography.....	12

Introduction

This assignment aims to evaluate the security (Penetration Testing) of applications running on the Android operating system and to demonstrate the exploitation of the insecure local data storage vulnerability.

- **Stage 1: Using the Apktool utility, we 'open' the application's files, allowing us to inspect the configuration files (AndroidManifest.xml), the source code in Smali format, and the resource files.**
- **Stage 2: We install the applications on a virtual mobile device within the Android Studio environment. While the application is running, we use the Device Explorer tool to inspect the files created in the application's private storage area (/data/data/<package>/).**

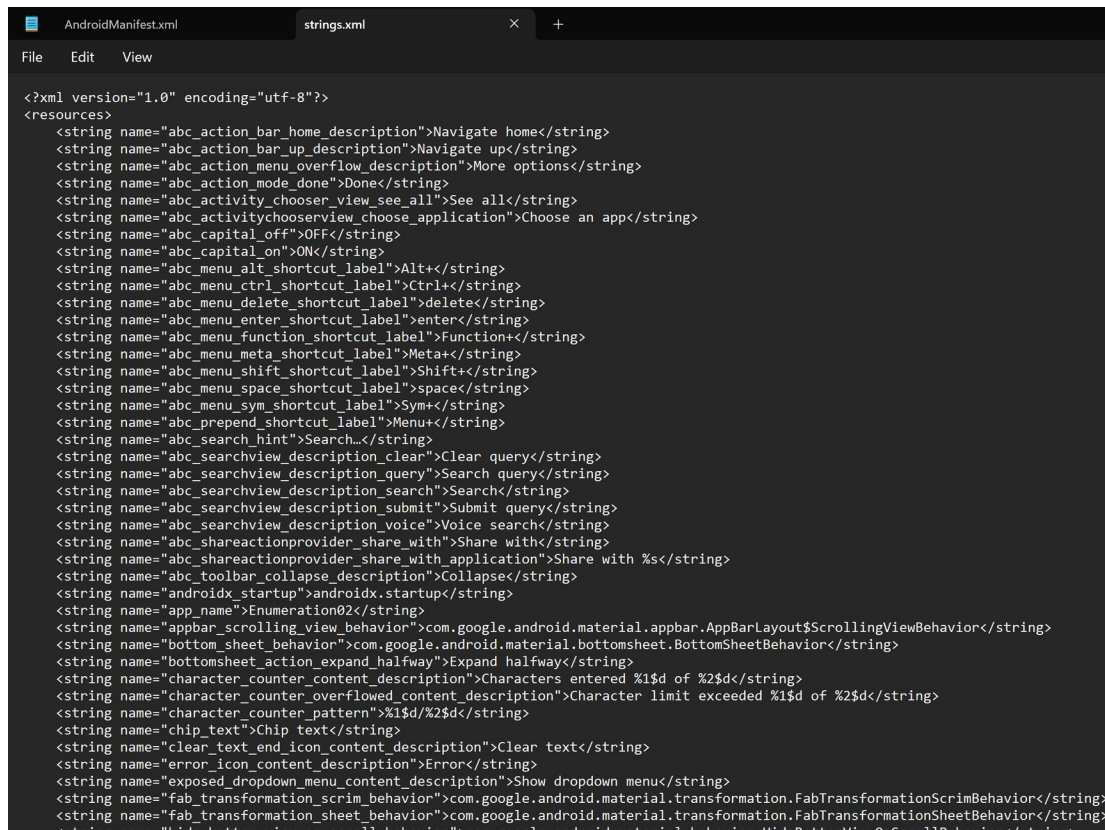
Frequently, developers rely exclusively on the protection provided by the operating system itself (sandboxing), neglecting the encryption of locally stored sensitive data.

Practical part of the assignment

The first stage of the investigation involved the analysis of the Enumeration02.apk application. Since Android installation files (.apk) are essentially ZIP archives, the process began with static analysis using Apktool.

In reverse engineering, analysis follows a hierarchy, starting from configuration files where developers tend to store sensitive information without encryption.

Subsequently, the examination moved to the resources directory and specifically to the res/values/strings.xml file. This file stores the application's string constants.

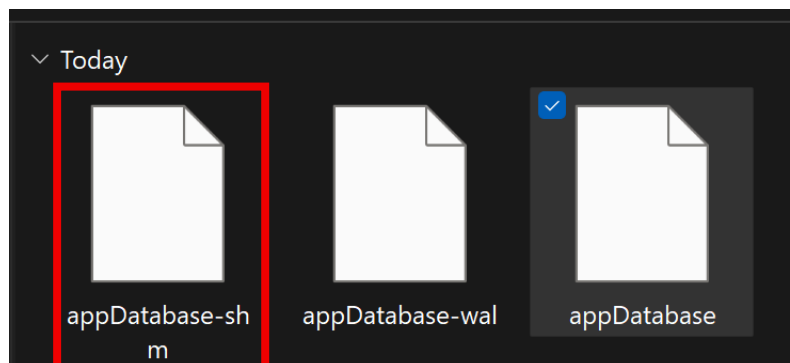
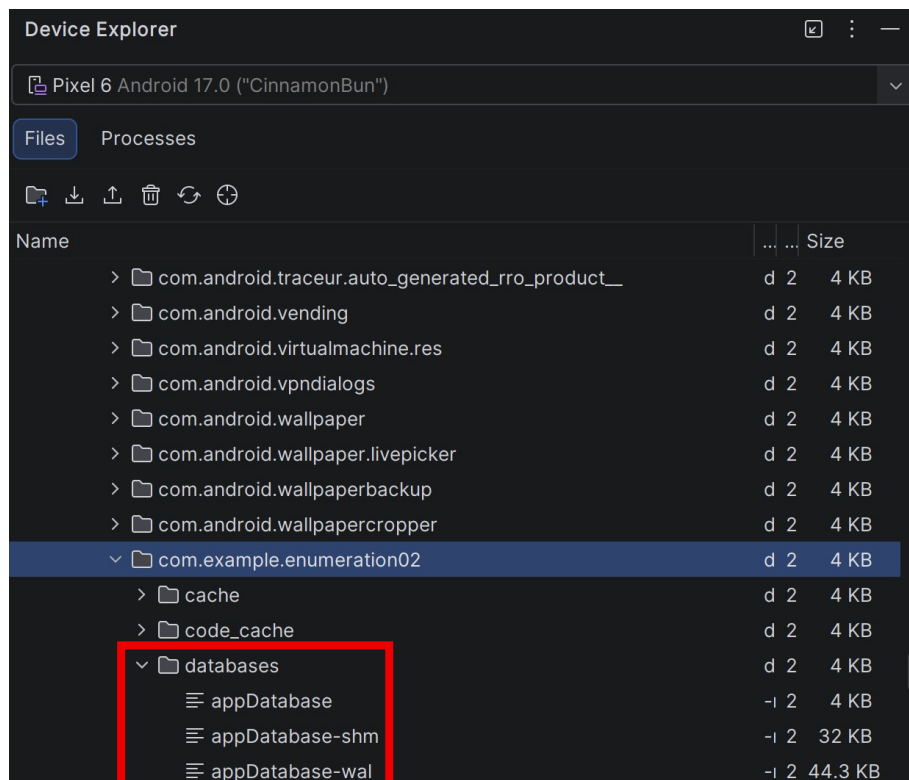


```
<?xml version="1.0" encoding="utf-8"?>
<resources>
    <string name="abc_action_bar_home_description">Navigate home</string>
    <string name="abc_action_bar_up_description">Navigate up</string>
    <string name="abc_action_menu_overflow_description">More options</string>
    <string name="abc_action_mode_done">Done</string>
    <string name="abc_activity_chooser_view_see_all">See all</string>
    <string name="abc_activitychooserview_choose_application">Choose an app</string>
    <string name="abc_capital_off">OFF</string>
    <string name="abc_capital_on">ON</string>
    <string name="abc_menu_alt_shortcut_label">Alt+</string>
    <string name="abc_menu_ctrl_shortcut_label">Ctrl+</string>
    <string name="abc_menu_delete_shortcut_label">delete</string>
    <string name="abc_menu_enter_shortcut_label">enter</string>
    <string name="abc_menu_function_shortcut_label">Function+</string>
    <string name="abc_menu_meta_shortcut_label">Meta+</string>
    <string name="abc_menu_shift_shortcut_label">Shift+</string>
    <string name="abc_menu_space_shortcut_label">space</string>
    <string name="abc_menu_sym_shortcut_label">Sym+</string>
    <string name="abc_prepend_shortcut_label">Menu+</string>
    <string name="abc_search_hint">Search...</string>
    <string name="abc_searchview_description_clear">Clear query</string>
    <string name="abc_searchview_description_query">Search query</string>
    <string name="abc_searchview_description_search">Search</string>
    <string name="abc_searchview_description_submit">Submit query</string>
    <string name="abc_searchview_description_voice">Voice search</string>
    <string name="abc_shareactionprovider_share_with">Share with</string>
    <string name="abc_shareactionprovider_share_with_application">Share with %s</string>
    <string name="abc_toolbar_collapse_description">Collapse</string>
    <string name="androidx_startup">androidx.startup</string>
    <string name="app_name">Enumeration02</string>
    <string name="appbar_scrolling_view_behavior">com.google.android.material.appbar.AppBarLayout$ScrollingViewBehavior</string>
    <string name="bottom_sheet_behavior">com.google.android.material.bottomsheet.BottomSheetBehavior</string>
    <string name="bottomsheet_action_expand_halfway">Expand halfway</string>
    <string name="character_counter_content_description">Characters entered %1$d of %2$d</string>
    <string name="character_counter_overflowed_content_description">Character limit exceeded %1$d of %2$d</string>
    <string name="character_counter_pattern">%1$d/%2$d</string>
    <string name="chip_text">Chip text</string>
    <string name="clear_text_end_icon_content_description">Clear text</string>
    <string name="error_icon_content_description">Error</string>
    <string name="exposed_dropdown_menu_content_description">Show dropdown menu</string>
    <string name="fab_transformation_scrim_behavior">com.google.android.material.transformation.FabTransformationScrimBehavior</string>
    <string name="fab_transformation_sheet_behavior">com.google.android.material.transformation.FabTransformationSheetBehavior</string>
```

Since the basic configuration files did not reveal the flag in plaintext and the findings from the Manifest analysis were inconclusive, the analysis proceeded to dynamic analysis — examining the application's runtime behaviour.

The use of a virtual device provides the necessary permissions (root) to access hidden system files. After the application was installed and executed, the Device Explorer tool was used to access the application's private data directory.

To examine the way passwords are stored, the Device Explorer tool of Android Studio was used. Navigating to the private storage area /data/data/com.unipi.project01/databases/, the database files were found.

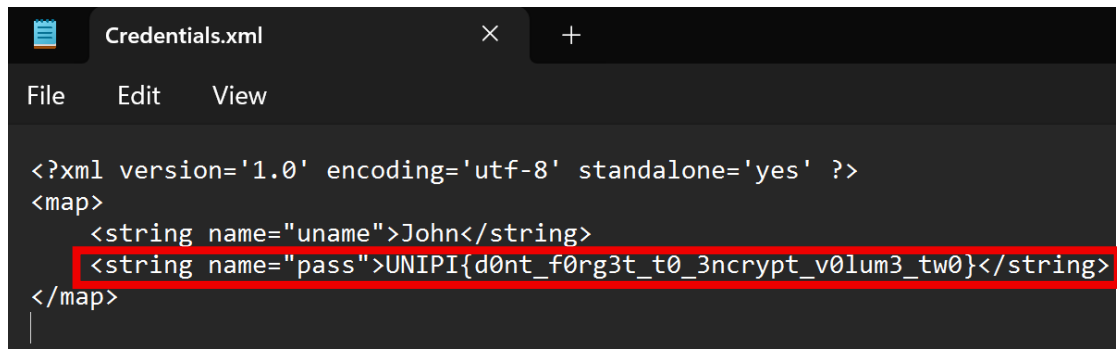


After extracting the files, the next step was examining their content. To check whether the application encrypts sensitive data, the files were examined with a hex editor. During the inspection of the temporary log file appDatabase-wal (Write-Ahead Log), it was revealed that the application stores the flag in plaintext — without any encryption. The absence of encryption in the local database allows any attacker with physical access — or access via a rooted device or ADB — to read all stored credentials in plaintext.

The evaluation of the second application (Enumeration03.apk) began following the same methodology. Using Apktool, the installation file was decompressed. Initially, the AndroidManifest.xml file was examined. Although no flag was found, the application's structure was confirmed.

The Enumeration03.apk application was installed and executed. The user interface (UI) confirmed our initial hypothesis: the application uses shared preferences for its authentication mechanism.

Following the dynamic analysis procedure, we used the Device Explorer tool again to investigate the private storage area of the application.



```
<?xml version='1.0' encoding='utf-8' standalone='yes' ?>
<map>
  <string name="uname">John</string>
  <string name="pass">UNIPi{d0nt_f0rg3t_t0_3ncrypt_v0lum3_tw0}</string>
</map>
```

The application presents the exact same vulnerability as the previous one, but implemented with a different mechanism. The developer used the SharedPreferences Android API to store the flag, mistakenly treating it as a secure storage mechanism.

Conclusion

This assignment highlighted in a practical way the importance of security testing (penetration testing) and reverse engineering in the mobile application development lifecycle, as well as the critical vulnerability of insecure data storage.

Bibliography

- HackerSploit. (2020, February 22). *Penetration Testing Bootcamp*. Retrieved from <https://www.youtube.com/watch?v=qJ9ZmkMvkcA>
- JohnHammond. GitHub - JohnHammond/security-resources: A communal outpouring of online resources for learning different things in cybersecurity. Retrieved from <https://github.com/JohnHammond/security-resources>

- David Bombal. (2021, May 5). *CTF Walkthrough with John Hammond* [Video file]. Retrieved from <https://www.youtube.com/watch?v=ZUqGSbvZp1k>
- OWASP MASTG - OWASP Mobile Application Security. Retrieved from <https://mas.owasp.org/MASTG/>
- OWASP Mobile Top 10 | OWASP Foundation. Retrieved from <https://owasp.org/www-project-mobile-top-10/>
- Data and file storage overview. Retrieved from <https://developer.android.com/training/data-storage>
- Save simple data with SharedPreferences. Retrieved from <https://developer.android.com/training/data-storage/shared-preferences>
- Write-Ahead logging. Retrieved from <https://sqlite.org/wal.html>